University of St.Gallen

Course and Examination Fact Sheet: Autumn Semester 2025

7,016: Managing IT Security and Privacy in Organisations

ECTS credits: 3

Overview examination/s

(binding regulations see below)
decentral - Written work, Digital, Individual work individual grade (25%)
Examination time: Term time
decentral - Presentation, Analog, Group work individual grade (50%)
Examination time: Term time
decentral - Active participation, Analog, Individual work individual grade (25%)
Examination time: Term time

Attached courses

Timetable -- Language -- Lecturer
7,016,1.00 Managing IT Security and Privacy in Organisations -- English -- Hein Andreas

Course information

Prerequisites

This course is assigned to the profile «Transforming and Managing Digital Business», but can also be taken without a selection of a specialization.

Learning objectives

In today's interconnected world, cybersecurity impacts every type of organization, from tech giants and startups to government agencies and non-profits. Individuals within these entities often represent the weakest link, making it imperative to cultivate a culture of vigilance and proactive risk management. If cybersecurity is not prioritized from the outset, the costs can be exorbitant, both financially and reputationally.

- The course is designed to equip future leaders with the knowledge and skills necessary to safeguard their organizations against information security threats.
- This course emphasizes the strategic and managerial aspects of IT security, focusing on how to foster a security-conscious culture and implement robust governance frameworks.
- Students will gain a deep understanding of the various IT risks organizations face and learn to implement industry-leading IT security management systems.
- They will explore strategies for promoting security and privacy awareness, ensuring that everyone in the organization is proactive in identifying and mitigating risks.
- The course will guide students through the development of comprehensive governance and compliance frameworks, enabling them to design policies that not only comply with legal requirements but also support the organization's strategic goals.
- This course will empower students to become leaders in IT security, capable of developing and executing risk management strategies and preparing their organizations to respond effectively to security incidents. Given that the employment of information security analysts is projected to grow by 32% from 2022 to 2032[1], far outpacing the average for all occupations, there is a clear and pressing need for professionals equipped with the skills and knowledge to navigate this challenging landscape.

  [1]: https://www.bls.gov/ooh/computer-and-information-technology/information-security-analysts.htm

Content

The course begins by examining what IT risks are and why organizations have to address them. Understanding these risks, from cyber-attacks to data breaches, is fundamental to protecting sensitive information and maintaining organizational integrity. This foundation sets the stage for understanding the broader implications of IT risks on organizational success and resilience.

As information privacy and security become increasingly vital, the course explores the rising costs associated with breaches in these areas. Students will learn about the financial, reputational, and operational impacts of security breaches, emphasizing the need for robust security measures. To bring these concepts to life, a case study will immerse students in the experience of managing a crisis, providing practical insights into the challenges and high-stakes decision-making involved in responding to IT security incidents.

Privacy management is another crucial component of the course, highlighting its importance in safeguarding personal and organizational data. Students will explore best practices for privacy management and understand the regulatory landscape that governs data protection. The course also covers information security risk management systems, teaching students how to implement and maintain these systems to mitigate risks effectively.

At the center of the course are the risk management process and management principles essential for developing resilient organizations. Students will explore new information security risks and emerging attack vectors, ensuring they stay ahead of evolving threats. The course ends in a final group presentation where students will apply their knowledge to identify, analyze, control, and monitor IT risks based on a famous case study in an organizational context.

Structure and indications of the learning and teaching design

- The course is structured to account for a total of 3 credits, equating to 90 hours of student workload. This includes self-study, campus time, and all examinations. The breakdown of this workload is designed to ensure comprehensive learning and application of course material.
- This course uses interactive learning methods, emphasizing real-life case studies to illustrate the complexities of managing IT and privacy-related risks. Through this hands-on approach, students will acquire applied knowledge in risk identification, analysis, controlling, and monitoring.
- The final exam is a group presentation where students will analyze a real-life incident, showcasing their ability to apply theoretical concepts to practical scenarios.

Contact Study:

- Lectures and case studies: The course begins with 15 hours of introductory lectures and case studies, where foundational concepts of IT security and privacy management are presented and internalized.
- Final presentation and individual report: At the end of the course, students will deliver a 30-minute group presentation, followed by a 15-minute discussion session. This presentation will assess their ability to analyze and manage IT security incidents based on real-life examples. Additionally, students will submit an individual report in which they describe how they would assess, manage, and control a specific risk.

Self-Study:

- Preparation for lectures: Students are expected to spend 4 hours preparing for the lectures, ensuring they are equipped with the necessary background knowledge and ready to engage in interactive sessions.
- Preparation for final presentation and individual report: The major component of self-study involves 35 hours dedicated to preparing for the final group presentation and the individual report. This preparation includes researching real-life incidents, analyzing risks, and developing strategies for risk management.
- Personal coaching: Students will receive 5 hours of optional personal coaching to guide them through the course material and their group project, providing individualized support to enhance their learning experience.

Location:

- The course will be conducted in person in St. Gallen, providing students with the opportunity to engage directly with instructors and peers, facilitating a collaborative and immersive learning environment.

Literature

The listed literature is optional and intended for those interested in further reading. All relevant concepts, definitions, and frameworks required for understanding and applying the course content will be fully covered during the lectures:

44 U.S. Code § 3542. *Definitions*.

Bauer, F. L. (2000). *Entzifferte Geheimnisse: Methoden und Maximen der Kryptologie*. Springer.

DeCew, J. W. (1997). *Pursuit of privacy: Law, ethics, and the rise of technology*. Cornell University Press.

Diesch, R., Pfaff, M., & Krcmar, H. (2018). Prerequisite to measure information security: A state-of-the-art literature review. *Proceedings of the 51st Hawaii International Conference on System Sciences (HICSS)*.

Farn, K.-J., Lin, S.-W., & Lee, W.-H. (2004). A study on information security management system evaluation—Assets, threat and vulnerability. *Computers & Security, 23*(1), 42–51. https://doi.org/10.1016/j.cose.2003.10.002

Fisher, K. A., Broadbent, A., Shalm, L. K., Yan, Z., Lavoie, J., Prevedel, R., ... & Resch, K. J. (2014). Quantum computing on encrypted data. *Nature Communications, 5*(1), 3074.

Gutwirth, S. (2002). *Privacy and the information age*. Rowman & Littlefield.

Hubbard, D. W. (2009). *The failure of risk management: Why it's broken and how to fix it*. Wiley.

Hussey, D. E. (1978). Portfolio analysis: Practical experience with the directional policy matrix. *Long Range Planning, 11*(4), 2–8.

ISO/IEC 27000:2018(E). (2018). *Information technology – Security techniques – Information security management systems – Overview and vocabulary*. International Organization for Standardization.

Loewenstein, G. F., Weber, E. U., Hsee, C. K., & Welch, N. (2001). Risk as feelings. *Psychological Bulletin, 127*(2), 267–286.

Nissenbaum, H. (2004). Privacy as contextual integrity. *Washington Law Review, 79*(1), 101–139.

Onn, Y., Sobel, M., Margalit, Y., Lavon, O., & Bigman, A. (2005). Privacy in the digital environment. *Haifa Center of Law & Technology*.

Ponemon Institute, & IBM Security. (2023). *Cost of a data breach report 2023*. IBM.

World Economic Forum. (2024). *Global risks perception survey 2024*. World Economic Forum.

Additional information

--

Examination information

Examination sub part/s

1. Examination sub part (1/3)

Examination modalities

Examination type	Written work
Responsible for organisation	decentral
Examination form	Written work
Examination mode	Digital
Time of examination	Term time
Examination execution	Asynchronous
Examination location	Off Campus

Grading type	Individual work individual grade
Weighting	25%
Duration	--

Languages
Question language: English
Answer language: English

Remark
--

Examination-aid rule
Free aids provision

Basically, students are free to choose aids. Any restrictions are defined by the faculty members in charge of the examination under supplementary aids.

Supplementary aids
--

2. Examination sub part (2/3)

Examination modalities

Examination type	Presentation
Responsible for organisation	decentral
Examination form	Oral examination
Examination mode	Analog
Time of examination	Term time
Examination execution	Asynchronous
Examination location	On Campus
Grading type	Group work individual grade
Weighting	50%
Duration	--

Languages
Question language: English
Answer language: English

Remark
--

Examination-aid rule
Free aids provision

Basically, students are free to choose aids. Any restrictions are defined by the faculty members in charge of the examination under supplementary aids.

Supplementary aids

None

3. Examination sub part (3/3)

Examination modalities

Examination type	Active participation

Responsible for organisation	decentral
Examination form	Oral examination
Examination mode	Analog
Time of examination	Term time
Examination execution	Synchronous
Examination location	On Campus
Grading type	Individual work individual grade
Weighting	25%
Duration	--

Languages
Question language: English
Answer language: English

Remark
--

Examination-aid rule
Free aids provision

Basically, students are free to choose aids. Any restrictions are defined by the faculty members in charge of the examination under supplementary aids.

Supplementary aids
--

Content

1. Group Project (50%)
Students will work in teams on a real-case study involving the practical application of IT security management concepts. The group work will be assessed based on the team's ability to identify, analyze, control, and monitor IT security risks in an organizational context. Specifically, the following aspects will be evaluated:

- **Risk Identification:**
  Identification of critical business processes, relevant assets (physical and digital), and associated risks and threats.

- **Risk Analysis:**
  Assessment of potential damage severity and likelihood of risk occurrence, resulting in a structured risk portfolio.

- **Risk Control:**
  Development of appropriate strategies for risk avoidance, mitigation (e.g., rollover, spreading), or acceptance, aligned with organizational priorities.

- **Risk Monitoring:**
  Design of monitoring and reporting mechanisms, scenario analyses, and continuous adjustment of the risk management approach.

2. Individual Report (25%)
Each student will submit a brief written report (approx. 3–5 pages) focusing on a specific IT security risk of their choosing. The report must demonstrate the student's ability to independently apply the full risk management cycle covered in the course:

- **Risk Identification** (e.g., affected assets and processes),

- **Risk Analysis** (e.g., damage potential and probability),

- **Risk Control** (e.g., proposed response strategies), and

- **Risk Monitoring** (e.g., indicators, follow-up mechanisms).

This report allows students to deepen their understanding of a concrete risk and showcase their analytical reasoning and methodological application.

3. Active Participation (25%)
Active engagement during lectures and case discussions is expected. Contributions to group exercises, preparedness, and critical engagement with the material will form the basis for this component of the grade.

Literature

See lecture slides.

Please note

Please note that only this fact sheet and the examination schedule published at the time of bidding are binding and takes precedence over other information, such as information on StudyNet (Canvas), on lecturers' websites and information in lectures etc.
Any references and links to third-party content within the fact sheet are only of a supplementary, informative nature and lie outside the area of responsibility of the University of St.Gallen.

Documents and materials are only relevant for central examinations if they are available by the end of the lecture period (CW51) at the latest. In the case of centrally organised mid-term examinations, the documents and materials up to CW 43 (Freitag, 24. October 2025) are relevant for testing.

Binding nature of the fact sheets:

- Course information as well as examination date (organised centrally/decentrally) and form of examination: from bidding start in CW 34 (Thursday, 21 August 2025);
- Examination information (supplementary aids, examination contents, examination literature) for decentralised examinations: in CW 42 (Monday, 13. October 2025);
- Examination information (supplementary aids, examination contents, examination literature) for centrally organised mid-term examinations: in CW 43 (Freitag, 24. October 2025);
- Examination information (regulations on aids, examination contents, examination literature) for centrally organised examinations: two weeks before ending with de-registration period in CW 45 (Monday, 03. November 2025).